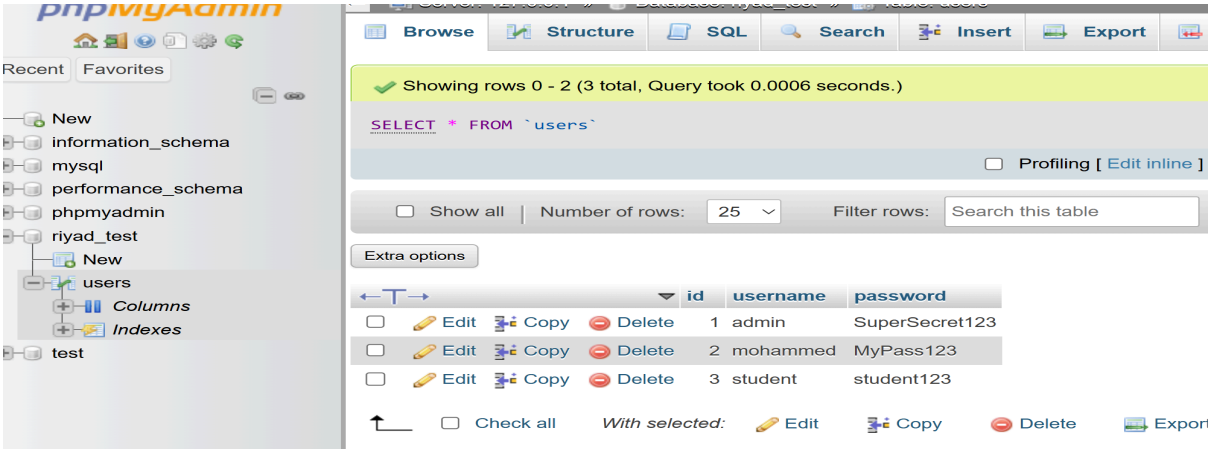
- في البداية تم تحميل برنامج XAMPP، وبعدها تم تنفيذ خطوات التاسك الأول وتجربته في الكلاس قبل المغادرة، وتم تجربة الـ payload ' OR '1'='1، وظهرت نتيجة LOGIN SUCCESS كما هو موضح في الصورة.



SQL: SELECT * FROM users WHERE username='' AND password='' OR '1'='1'

LOGIN SUCCESS!

username
password
Login

- تم إنشاء ملف dump.php في مسار simple-sqli، وتم إرفاق الكود اللي موجود فيه ثغرة UNION Injection، وتم تجربة الثغرة ونجحت وسبب الثغرة إن الكود يلصق مدخلات اليوزر والباسورد مباشرة جوا نص استعلام SQL بدون أي فلترة للمدخلات فصار المستخدم يقدر يكتب رموز خاصة زي ' ويغير معنى الاستعلام وينفذ أمر UNION يسحب بيانات كل اليوزرات من الجدول.

SQL: SELECT * FROM users WHERE username='' UNION SELECT 1, username, password FROM users -- ' AND password='v'

LOGIN SUCCESS!

Returned rows:

```
1 | admin | SuperSecret123
1 | mohammed | MyPass123
1 | student | student123
```

username

password

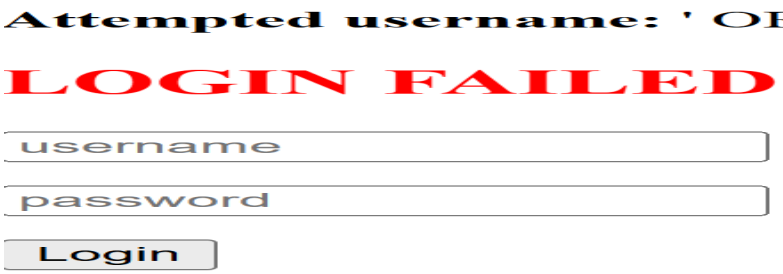
Login

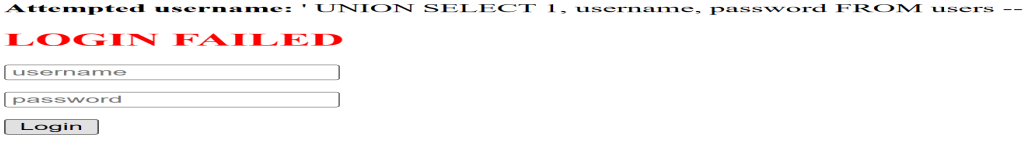
- تم إنشاء ملف secure.php بنفس فكرة السابقة لكن تم استبدال طريقة دمج المدخلات المباشرة في نص SQL اللي كانت سبب الثغرة حيث تم تغير الجزء

```
$sql = "SELECT * FROM users WHERE username='" .
$username . "' AND password='" . $password . "'";
$result = mysqli_query($conn, $sql);
```

واستبداله بهذا الجزء بدل ما نحط قيمة المستخدم مباشرة جوا نص SQL حطينا علامة ? مكانها. بعدين قاعدة البيانات تاخذ قيمة username وpassword بشكل منفصل عن الاستعلام يعني حتى لو المستخدم كتب رموز SQL زي ' أو UNION، قاعدة البيانات تتعامل معها كلام عادي بس وما تنفذها كأمر.

```
$stmt = mysqli_prepare($conn, "SELECT * FROM users
WHERE username=? AND password=?");
mysqli_stmt_bind_param($stmt, "ss", $username,
$password);
mysqli_stmt_execute($stmt);
$result = mysqli_stmt_get_result($stmt);
```





(Riyad Alshehri)